CARLOS TIBURCIO

Kerberos Password-Guessing Detection

Balcom Insurance Homelab | DET01

Wazuh custom rules • Active Directory • Detection validation

PROJECT GOAL

Detect a short burst of Kerberos wrong-password failures against one account from one source, then test the conditions that should keep the alert quiet.

> **Result:** Rule 110101 fired for five qualifying failures within 120 seconds. Four negative tests confirmed the count, source, time-window, and account boundaries in this lab.

2	5	120s	2
Custom rules	Validation tests	Correlation window	Client systems

I built DET01 on the telemetry platform from SOC01. This case study follows the event from the workstation to DC01 and Wazuh, explains the rule logic, and records the positive and negative test results.

Completed October 22, 2026. Balcom Insurance is a fictional organization used to structure my personal lab. All authentication tests targeted dedicated lab accounts.

01 / SCOPE & TELEMETRY

Start with the event, then build the detection

SOC01 gave me centralized telemetry. DET01 was the next step: turn a specific authentication pattern into a tested alert. I generated controlled failures with Windows runas and followed the resulting Security events into Wazuh.

System	Address	Role in DET01
DC01	10.10.20.100	Domain controller; Security log source; Wazuh agent 001
WAZUH01	10.10.30.100	Manager, indexer, and dashboard
IT-PC01	10.20.10.121	Primary source of test logons
SALES-PC01	10.20.20.168	Second source for separation testing

The existing Proxmox and OPNsense environment supplied the VMs, routing, and segmentation. The domain was **homelab.internal**; the dedicated accounts were **det01.user01** and **det01.user02**.

The signal I selected

Windows Event ID **4771** records Kerberos pre-authentication failure on the domain controller. DET01 selects status **0x18**, the wrong-password condition exercised in these tests. Success and failure auditing were checked before validation. [1]

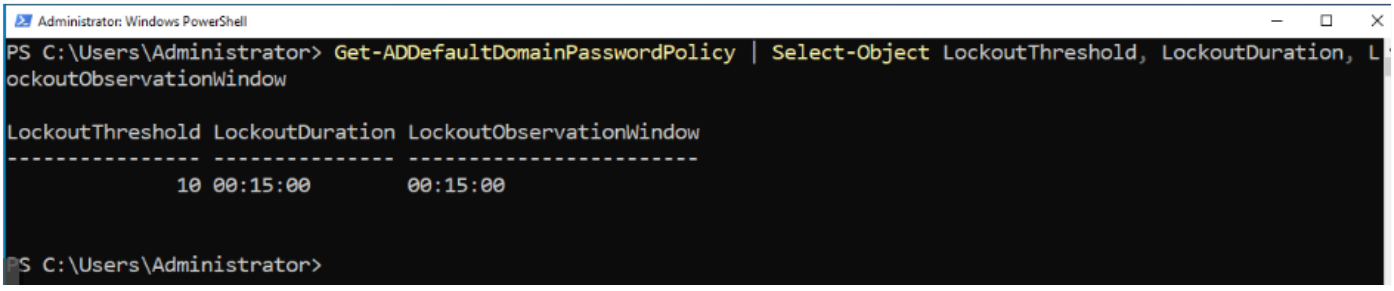


Figure 1. The lab policy allowed 10 failed attempts before lockout, with 15-minute lockout and observation windows.

> **Two different counters:** Active Directory badPwdCount helped me track account state. Wazuh maintained its own correlation history. Resetting the AD count did not clear Wazuh's 120-second window.

02 / DETECTION DESIGN

One rule identifies failures. One groups them.

I kept the rules in **det01_rules.xml**. Rule 110100 matches a single qualifying failure at level 5. Rule 110101 raises a level 10 alert when five matching events share the same target account and client address within 120 seconds.

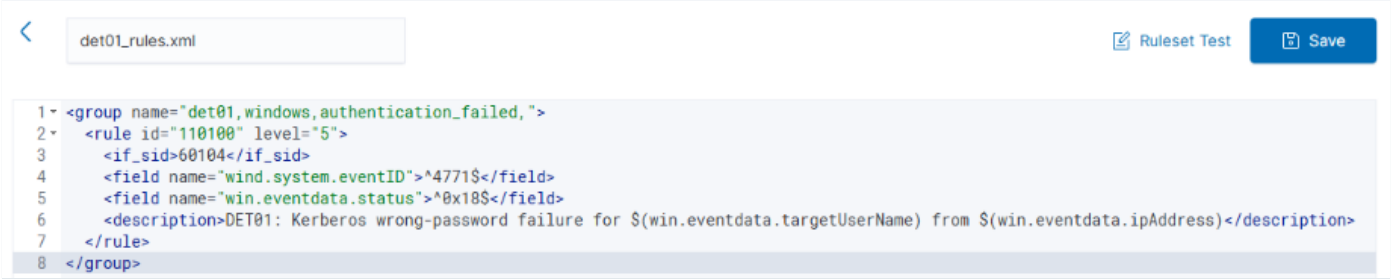


Figure 2. The base rule inherits from 60104 and checks win.system.eventID and win.eventdata.status. This capture shows the base rule before the correlation rule was added.

Rule / purpose	Tested logic
110100 · single failure	Event 4771 + status 0x18
110101 · correlation	Five matches of 110100 within 120 seconds; same win.eventdata.targetUserName and win.eventdata.ipAddress

VALIDATION PLAN & OBSERVED RESULTS

Scenario	Input	Observed outcome
Positive	5 failures; same account and IP; within 120s	110101 fired
Below threshold	4 failures; same account and IP	4 base alerts; no 110101
Source separation	2 from IT + 3 from Sales; one account	5 base alerts; no 110101
Time window	2 failures, wait >120s, then 3	5 base alerts; no 110101
Account separation	2 for user01 + 3 for user02; one IP	5 base alerts; no 110101

The positive alert and the negative tests are the deployment evidence. The configuration above summarizes the tested conditions; it is not presented as a full export of the final XML. Wazuh's rule reference explains frequency, timeframe, if_matched_sid, and same_field. [2]

03 / POSITIVE TEST

Five failures produced the expected alert

From IT-PC01, I entered incorrect passwords for det01.user01 in a short burst. Wazuh produced rule **110101** at **level 10**, with **frequency 5**. The displayed alert time was October 22 at **15:18:10.611**.

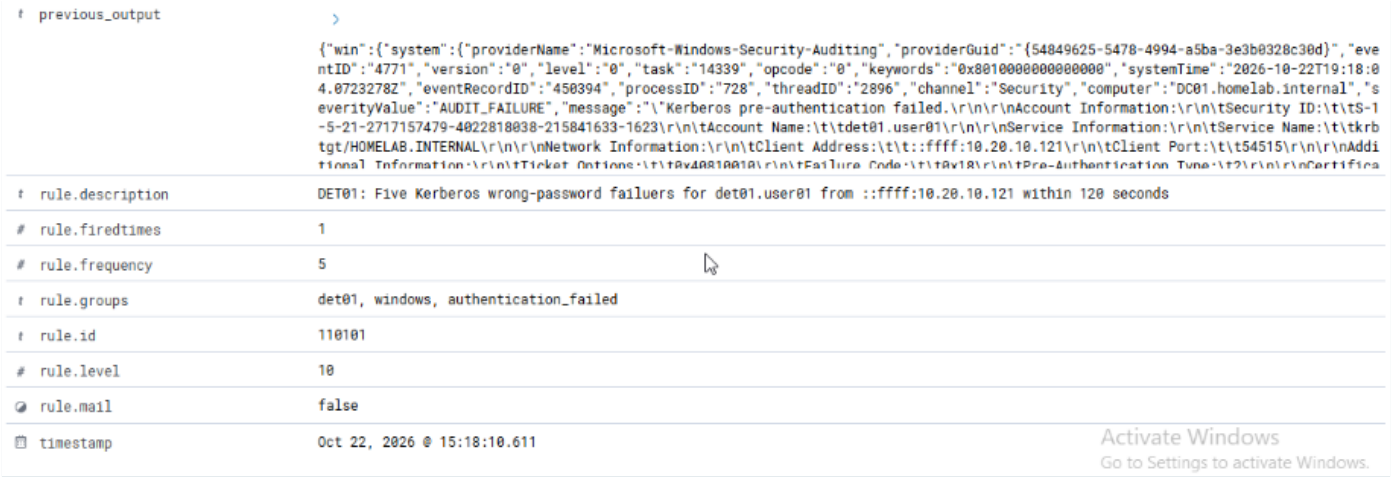


Figure 3. Live correlation alert showing rule ID, severity, frequency, description, and previous_output.

What previous_output proved

I expanded previous_output and checked the supporting records. All four showed Event 4771, status 0x18, det01.user01, and ::ffff:10.20.10.121. The current event, record 450397, was the fifth event in the alert.

Supporting record	Windows systemTime (UTC)
450391	19:17:50.0700996Z
450392	19:17:55.7403979Z
450393	19:18:00.6161036Z
450394	19:18:04.0723278Z

Read the right count: rule.firedtimes = 1 described one firing of the correlation rule. The five-event condition was supported by the current event plus four earlier events.

The dashboard used local time (UTC−4); Windows systemTime values ending in Z were UTC. These are different time representations. I used record IDs and the shared account/source fields to connect the evidence.

04 / NEGATIVE TEST

Four failures stayed below the threshold

I generated four failures for the same account from IT-PC01. The base-rule search showed four hits. A separate search for rule 110101 covering the test period returned no results.

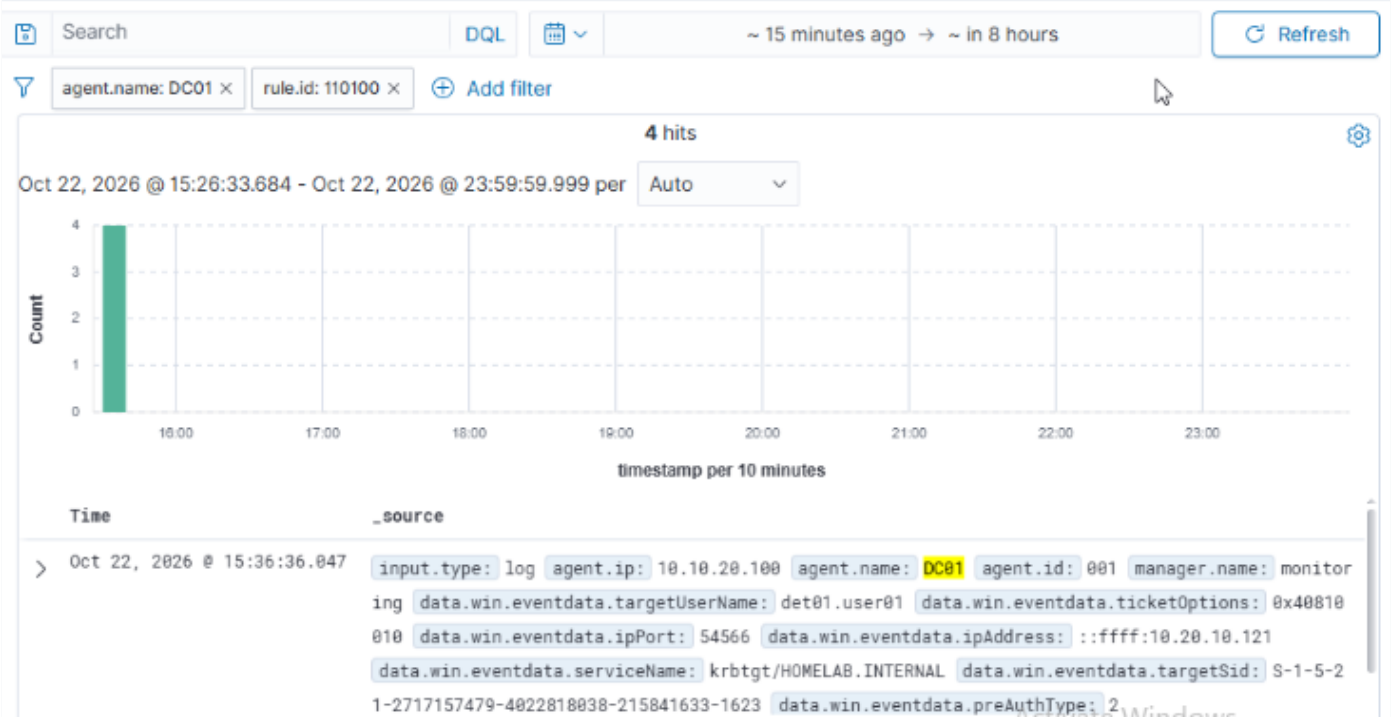


Figure 4. Four rule 110100 hits were visible during the below-threshold test.

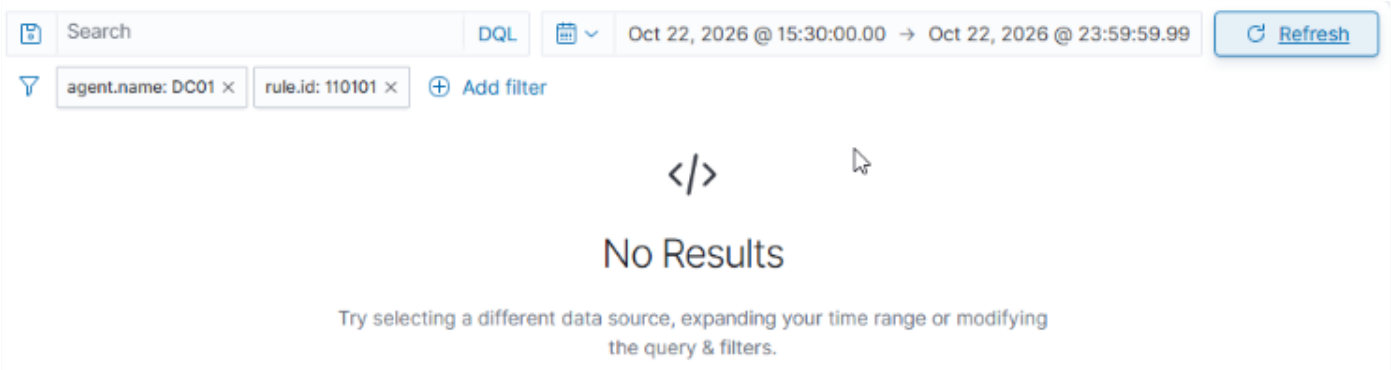


Figure 5. The rule 110101 search covered the 15:36 test and returned no results.

> **Why this test matters:** Seeing the base events confirmed that telemetry was arriving. The quiet correlation rule showed the count condition held for this test.

05 / NEGATIVE TEST

Two workstations did not combine into one burst

I used det01.user01 on both clients: two failures from IT-PC01 and three from SALES-PC01. The five base alerts arrived within about 26 seconds. Rule 110101 did not fire.

@timestamp	Oct 22, 2026 @ 15:55:33.027
_index	wazuh-alerts-4.x-2026.10.22
agent.id	001
agent.ip	10.10.20.100
agent.name	DC01
data.win.eventdata.ipAddress	::ffff:10.20.10.121
data.win.eventdata.ipPort	54637
data.win.eventdata.preAuthType	2
data.win.eventdata.serviceName	krbtgt/HOMELAB.INTERNAL
data.win.eventdata.status	0x18
data.win.eventdata.targetSid	S-1-5-21-2717157479-4022818038-215841633-1623
data.win.eventdata.targetUserName	det01.user01
data.win.eventdata.ticketOptions	0x40810010
data.win.system.channel	Security
data.win.system.computer	DC01.homelab.internal
data.win.system.eventID	4771

@timestamp	Oct 22, 2026 @ 15:55:17.777
_index	wazuh-alerts-4.x-2026.10.22
agent.id	001
agent.ip	10.10.20.100
agent.name	DC01
data.win.eventdata.ipAddress	::ffff:10.20.20.168
data.win.eventdata.ipPort	61244
data.win.eventdata.preAuthType	2
data.win.eventdata.serviceName	krbtgt/HOMELAB.INTERNAL
data.win.eventdata.status	0x18
data.win.eventdata.targetSid	S-1-5-21-2717157479-4022818038-215841633-1623
data.win.eventdata.targetUserName	det01.user01
data.win.eventdata.ticketOptions	0x40810010
data.win.system.channel	Security
data.win.system.computer	DC01.homelab.internal
data.win.system.eventID	4771

Figure 6. Expanded events from IT-PC01 (left) and SALES-PC01 (right). The collecting agent stays DC01 while the client address changes.

> **Observed split:** Three base alerts carried client 10.20.20.168 and two carried 10.20.10.121. All five targeted det01.user01 and arrived within about 26 seconds.

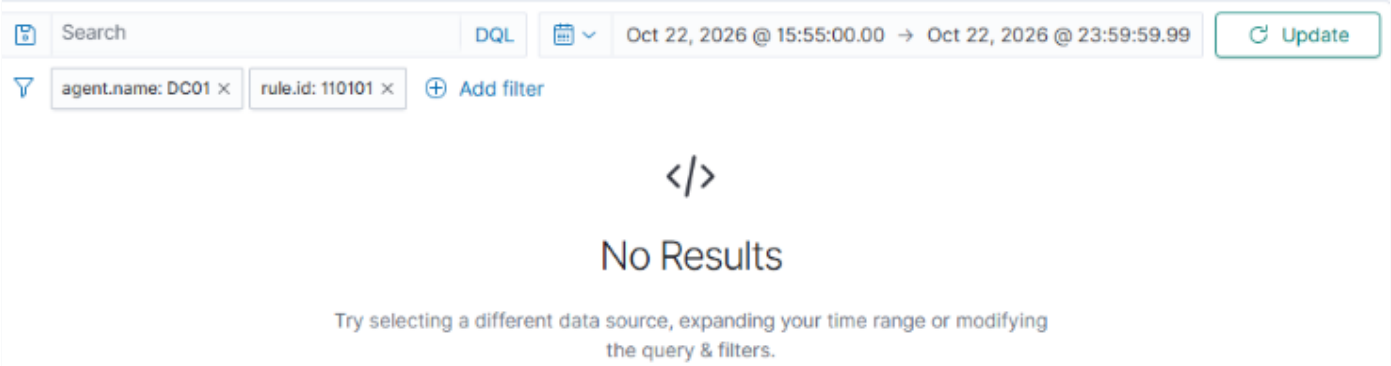


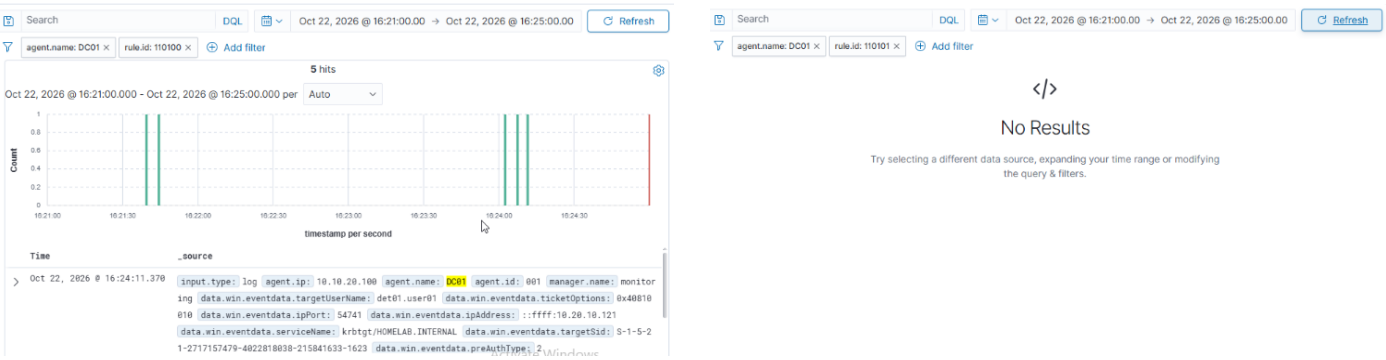
Figure 7. The correlation-rule search returned no results after the source-separation test.

The field distinction: agent.ip identifies the machine collecting the log. data.win.eventdata.ipAddress identifies the client in this Windows event. The ::ffff: prefix is the IPv4-mapped IPv6 representation. Using the DC's agent address as the client key would group unrelated workstations together.

06 / NEGATIVE TEST

Five failures outside the window stayed separate

I generated two failures, waited more than 120 seconds, and generated three more for the same account and client. The final search window, 16:21 to 16:25, contained five base alerts and no rule 110101 alert.



Figures 8-9. The completed retest shows two groups of rule 110100 events separated by more than two minutes (left); the same 16:21-16:25 window contains no rule 110101 alert (right).

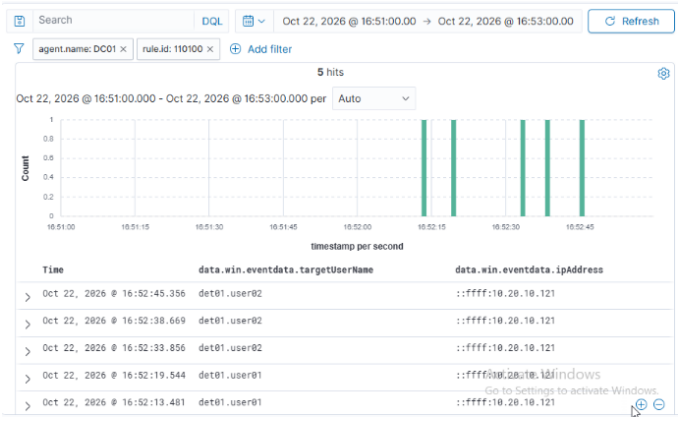
> **What this proves:** The rule did not treat five failures anywhere in the dashboard’s search range as one qualifying burst. Its correlation window remained 120 seconds.

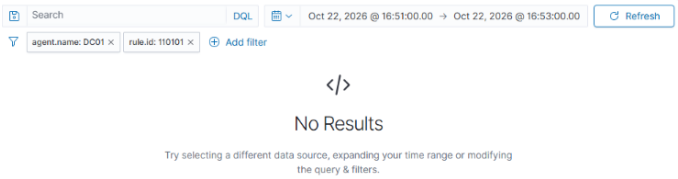
An earlier attempt had only three generated failures and a confusing search range. I corrected the test, checked the account state, and repeated it. The figures here show the completed five-event retest.

07 / NEGATIVE TEST

Different accounts kept separate counters

The final test kept the client address fixed at ::ffff:10.20.10.121. I generated two failures for det01.user01 and three for det01.user02. All five occurred within **31.875 seconds**, so timing could not explain the quiet correlation rule.





Figures 10-11. The event table shows two failures for user01 and three for user02 at one client address (left); the matching 16:51-16:53 search contains no rule 110101 alert (right).

Conclusion: The five failures did not combine across accounts. Together with the two-workstation test, this confirmed both grouping conditions under the tested lab scenarios.

Adding targetUserName and ipAddress as table columns made this result much easier to review than opening every event individually.

08 / TROUBLESHOOTING & INVESTIGATION

The useful work was in checking the assumptions

Issue I encountered	How I resolved or interpreted it
The expected alert was missing	I checked the test command and the actual 4771 event before changing the rule. A command typo had prevented the intended test.
The rule test returned 1002	The pasted full_log JSON decoded as json in that test session. The live Windows pipeline used windows_eventchannel. I treated the mismatch as a test-context issue and validated with live events.
A saved rule did not affect live testing	After the rule edits, I restarted the Wazuh manager and generated fresh events. Saving a custom rule and loading it into live analysis are separate steps. [3]
Search totals did not match my attempts	I checked the absolute time range, rule filter, account, source, and event records. I repeated the incomplete timing test instead of counting stale hits.
DC01 appeared as the agent IP	I followed the client address inside the Windows event. The DC records Kerberos failures caused by other hosts.

How I would triage a DET01 alert

1. Confirm the evidence. Check 4771, status 0x18, the target account, source address, current event, and previous_output.

2. Establish context. Identify the owner and expected use of the account and workstation. Check for an ordinary typing mistake, a service, or a scheduled task with an old password.

3. Follow the timeline. Review nearby successful logons, lockout events, and other activity from the same source. DET01 itself does not correlate those events.

4. Record the decision. Document the evidence and investigation result before recommending a response. A burst of failures alone does not prove account compromise.

09 / OUTCOME & LIMITS

A small detection with a clear, tested scope

DET01 met its lab objective: five wrong-password Kerberos failures for one account from one client within 120 seconds produced the correlation alert. The four negative tests stayed quiet while the base telemetry remained visible.

What I took from the project

I learned to validate the event first, choose grouping fields deliberately, and prove the quiet cases as carefully as the firing case. The biggest improvement in my workflow was making the evidence readable: fixed time ranges, separate rule filters, useful table columns, and supporting event records.

Coverage boundaries

This rule covers the tested 4771 / 0x18 pattern. Low-frequency attempts outside the window, failures split across sources or accounts, other authentication protocols, and other failure codes need separate detection logic. Cross-domain-controller correlation, load behavior, and production alert volume were not tested.

Repeated user mistakes and stale service credentials can create the same signal. No measured production false-positive rate, automatic blocking, or compromise detection is claimed. The five passing scenarios describe this validation set.

> **ATT&CK context:** The behavior maps to T1110.001, Password Guessing. This is an analytical mapping of the test behavior; it does not imply that ATT&CK metadata was added to the rule XML. [4]

Next iteration

I would add repeatable event replay, test a second domain controller, and build separate logic for password spraying or failure-followed-by-success sequences. Those are future extensions to the validated baseline.

REFERENCES & EVIDENCE

1. **Microsoft Learn.** Event 4771: Kerberos pre-authentication failed.
2. **Wazuh.** Rules syntax: frequency, timeframe, and correlation fields.
3. **Wazuh.** Custom rules: location, testing, and manager restart.
4. **MITRE ATT&CK.** T1110.001: Password Guessing.

Evidence: original screenshots and event JSON captured during the October 22, 2026 lab session. Screenshots are cropped for focus; event values are unchanged. Source references checked October 22, 2026.

Online case study and expandable evidence